

Database break-in

Revise 360 lesson plan — 60 minutes

Unit	OCR J277 1.4 Network security — Paper 1, Computer systems
Lesson	Database break-in (lesson 3 of the unit)
Lesson ID	ns-l03
Experience ID	ns-l03
Plan ID	PLAN-NS-L03
Content version	fb5bcd9c11
Website	https://revise360.co.uk/experience.html?id=ns-l03

Big question, outcomes and success criteria

Big question — How does an SQL injection attack work, and how can it be prevented?

Prerequisites

The lesson before this one is ns-l02. Pupils should already have finished it: the starter below retrieves from it.

Earlier in the unit: ns-l01.

Assessable outcomes

1. **ns-l03-o1** — understand the concept of SQL injection
2. **ns-l03-o2** — understand how to protect against SQL injection

Vocabulary, resources and preparation

Key vocabulary — SQL injection, Input validation

Resources

SLIDES	presentations/NS_L03_DatabaseBreakIn_Lesson.pptx
WORKSHEET	worksheets/NS_L03_DatabaseBreakIn_Worksheet.docx
ONLINE EXPERIENCE	experience.html?id=ns-l03

Before the lesson

1. Sign in on the **teacher dashboard** (teacher.html) and open **Class logins**. Enter the class or group and the usernames, one per line, then print the login cards. A pupil cannot sign in without one, so do this before the lesson rather than in it.
2. Print the worksheet, one per pupil.
3. Open the slides and the experience once yourself, on the machine you will be teaching from, so the 360 image is already cached.
4. Check headsets or devices are charged and on the school network.

How pupils get in

1. Go to `topics.html` on `revise360.co.uk`.
2. Sign in with the **username and PIN from the login card**. The class is already set against the card.
3. Choose the topic, then this lesson's card.

Worth knowing before you promise anything. In this build `APP_CONFIG.backendUrl` is empty, so logins, login cards and progress are stored on the device the pupil used. The teacher dashboard says so too. A pupil who moves to a different machine starts again, so keep a class on the same devices within a unit, and treat the paper worksheet as the record that travels.

Teaching sequence

Sixty minutes including transitions. The online block is the one to move if your lesson is shorter: see the adaptation at the end.

MIN	PHASE	TEACHER	PUPILS	EVIDENCE TO CHECK
0-5	Retrieve	Starter on the board or the worksheet, from the last lesson and this lesson's prerequisites.	Answer the starter on the worksheet.	The starter box on NS_L03_DatabaseBreakIn_Worksheet.docx is filled in.
5-8	Review the starter	Take answers; correct the one most got wrong.	Correct their own starter.	A correction written, not just a tick.
8-18	Explain and model	The new idea in two or three steps, with the example worked in front of the class.	Listen and answer questions about the example.	They can say why, not only what.
18-21	Set up and settle	Sign-in, launch, and what to write before anyone taps an answer.	Sign in, open the lesson, find Databases and SQL.	Everyone is in and on station 1.
21-43	Online: work the stations in order	Pupils read each wall, write the key fact and the challenge, then answer at the badge.	Read each wall, write the key fact and the challenge, then answer at the badge.	The worksheet has writing on it for each of the 6 stations before the badge is tapped.
43-48	Check understanding	The hinge question, hands down.	Answer the hinge question, hands down.	The split across the options.
48-56	Apply	Exam practice on the worksheet, in silence.	Exam practice, in silence.	worksheet, Exam practice a) to b)
56-60	Exit and set up the next lesson	The exit question and the retrieval link to next lesson.	Write the exit answer.	One sentence that answers the big question.

The explanation and the worked example

This is what the walls of the experience say, station by station. Teach the first two or three from the front before anyone puts a headset on; the rest the pupils read for themselves.

1. Databases and SQL

- Websites store usernames, passwords and records in a database.
- SQL (Structured Query Language) is used to ask the database for records, and to add, change or delete them.
- `SELECT * FROM users WHERE name = 'Sam'` asks for Sam's record.

Challenge on this wall: Write in your own words what SQL is used for.

2. The dangerous line

- The code in your starter joins the user's input onto the query as text.
- Joining a string to a variable like this is called concatenation.
- Whatever the user types becomes part of the SQL command.

Challenge on this wall: Which line of the starter code is the dangerous one, and why?

3. The attack

- An attacker types SQL into the text box instead of a username.
- Entering `' OR 1=1 --` makes the condition always true and comments out the rest.
- The database returns every record, and the attacker is logged in.

Challenge on this wall: Explain how typing ' OR 1=1 -- into a login box can work.

4. What attackers gain

- Log in as another user, including an administrator.
- Read every record: names, emails, passwords and card details.
- Change or delete records, or even destroy whole tables.

Challenge on this wall: What could an attacker do with a school's student database?

5. Stopping injection

- Validate input: check it matches what's expected, such as letters and numbers only.
- Sanitise input: remove or escape dangerous characters like quotation marks.
- Use parameterised queries, which keep the user's input separate from the SQL command.
- Give the website's database account only the permissions it needs.

Challenge on this wall: Which defence is the strongest, and why?

6. Testing for holes

- Penetration testers deliberately try injection attacks to find weaknesses.
- Detailed error messages help attackers, so live sites should hide them.
- Old, unpatched website software is a common way in.

Challenge on this wall: Why should a live website never show detailed database errors?

Retrieval and the check for understanding

Starter — A website login box passes whatever you type straight into a database query. Suggest what could go wrong, and who might take advantage of it.

Answer space: 3 lines on the worksheet.

The answer is in the teacher answers for this unit, not on this plan: a plan left on a desk should not give it away.

Hinge question

Use this one, hands down, before anyone moves on to independent work. It is a real activity from the experience (ns-103-s3-c2), so the wording a pupil sees matches the wording you say.

What is the -- for?

Correct: It turns the rest of the line into a comment, so it is ignored

What a pupil might choose instead

- It adds two records
- It subtracts a value
- It joins two tables

Count the hands on each. If more than a few of the class are on one wrong option, that option is the misconception to teach against before anyone goes on: go back to the station this question sits on and work through its example again, aloud, before the independent work.

The course's own response to a wrong answer here: Commenting out the rest removes anything that would break the attacker's query.

One response, not four. one response covers every wrong option; it does not say what to revisit for each one, so decide your own reteach for each option before the lesson - the list above is the start of it.

Guided to independent practice

STAGE	ACTIVITIES	WHAT IT IS
Recognise	11	The answer is on the screen and the pupil picks it: multiple choice, choosing several, matching a pair.
Construct	1	Nothing is offered. The pupil classifies, orders, fills in a table or works a number out, and types or places the answer.

Scaffolds already in the product, and how they fade

- **Hint** is a ladder, not a door: the first rung names the idea, the next shows the shape of the code, the next how it starts, the last animates the technique on different data. A pupil asks for each rung. None of them is the answer.
- **Run** is free and unmarked; **Check my answer** marks. A pupil may run as often as they like, which is what makes trial and error safe.
- **I need help** says to ask you, and says plainly that the question still has to be completed. It does not notify anyone and it does not unlock anything.
- The worked example appears on every early activity and on none of the late ones. That fade is deliberate; it is not a missing example.

Accessibility

- **Read aloud** on every task window reads the task and its brief, with the prescribed values read as values rather than as punctuation.
- Text is 16px or larger throughout, and a question window scrolls rather than shrinking its type.
- Prescribed data is boxed and in a monospace face as well as coloured, so it still reads as code in black and white, in a high-contrast mode, and to a pupil who does not separate green from amber.
- **Lower literacy and EAL:** pre-teach the vocabulary above; let the pupil say the key fact before writing it; accept the key fact in two or three words.
- **SEND:** the sequence is compulsory but the pace is not. A pupil may finish a station next lesson; the progress saves after every answer and reopens at their earliest unfinished question.
- A headset is never required. Every experience works on a laptop or a tablet with a mouse or a finger.

Delivering the online experience

Before anyone enters

- Worksheet out, pen in hand. The rule is write first, then answer at the badge: the first answer is the one that counts.
- Say where the stations are. They are numbered around the room: 1 and 2 to the right, 3 and 4 behind, 5 and 6 to the left, and the final challenge on the floor.
- Say that a badge marked **Not yet** is not a fault. It opens when the station they are on is finished.

The stations, and what to record at each

#	STATION	ACTIVITIES	RECORD ON PAPER
1	Databases and SQL	2	SQL is used to...
2	The dangerous line	2	The problem with the code is...
3	The attack	2	An SQL injection attack works by...
4	What attackers gain	1	A successful SQL injection lets an attacker...
5	Stopping injection	2	SQL injection can be prevented by...
6	Testing for holes	2	To find weaknesses, organisations...
final	Final challenge: secure the login	1	the answer to the station's challenge

Where to pause

Stop the class after station 2 and take answers to its challenge out loud. That is the point where a pupil who has misread the technique can still be put right cheaply.

Afterwards

Headsets off and down. Ask three pupils for the key fact from a station of your choosing, in their own words and not read off the sheet. Then the exit question.

Assessment, evidence and unfinished work

ID	QUESTION	MARKS	WHERE
ns-103-x1	Describe what happens during an SQL injection attack.	3	worksheet, Exam practice a); deck, Exam practice slide
ns-103-x2	Explain two techniques a programmer can use to prevent SQL injection.	4	worksheet, Exam practice b); deck, Exam practice slide

Expected answers

Model answers and marking guidance are teacher-only and are not printed on this plan. They are in the unit's teacher guide pack, and the per-activity marking for this lesson is in `answers/records/ns-103.json`, which is not published with the website.

Common errors

The wrong options the activities offer are the errors this lesson expects. The commonest to watch for:

- **What is SQL used for?** — Designing web page layouts; Encrypting Wi-Fi traffic
- **Which part of a website would use SQL?** — The colour scheme; The font size
- **Joining a string to a variable, as in 'uname = ' + username, is known** — Compilation; Compression
- **Why is building a query this way dangerous?** — It makes the website load slowly; It uses too much memory
- **What does 'OR 1=1 do inside a query?** — It deletes the database; It encrypts the password

Unfinished work

Record where each pupil stopped, not a tick. They resume at their earliest unfinished question, and a station left half-done is the thing to open next lesson. Do not mark the lesson complete for a pupil who did not finish it: the score screen already shows what was and was not done, and that is the honest record.

Exit, next lesson and homework

Exit check

One of these, written, not a show of hands:

- What SQL injection is
- How the attack works
- How to protect against it

The confidence columns on the worksheet are a supplement to this, not a substitute: a pupil who rates themselves confident and cannot answer the exit question has told you nothing.

Retrieval link to next lesson

Next is ns-104, Phishing inbox. Use this lesson's big question as next lesson's starter, so the first thing they do is retrieve it.

Homework

Finish any station left open, on the website, from the question they stopped at. If the class has no devices at home, set the exam practice on the worksheet instead and mark it next lesson.

Shorter lessons, longer lessons and no internet

A 40 to 45 minute lesson

Keep the starter, the explanation and the model at full length: cutting those is what makes the online work fail. Take the time out of the online block and the apply phase. Pupils stop where they are; their progress saves after every answer and reopens at their earliest unfinished question, so the next lesson starts there.

If the internet or the devices are unavailable

Teach from the slides and the worksheet. The slides carry the same teaching as the station walls, and the worksheet carries the key facts, the challenges and the exam practice. Set the online stations when the devices are back.

There is no offline version of the experience, and this plan does not contain one. Do not hand out a printed walkthrough of the stations as a substitute: the experiences are used on the website.

